

Data Privacy and Information Security Standards

Section 1.0: Data Classification and Handling

Data handled by corporate systems is classified into three tiers: Tier 1 (Public Marketing Materials), Tier 2 (Internal Business Operations), and Tier 3 (Restricted Customer PII and Financial Records). Tier 3 records must be encrypted at rest using AES-256 and in transit using TLS 1.3.

Section 2.0: Password Complexity and Session Timeouts

All corporate user accounts require passwords of at least 16 characters including uppercase, lowercase, numbers, and special symbols. Passwords must be rotated every 90 days. Unattended workstation sessions must automatically lock after 10 minutes of inactivity.

Section 3.0: Incident Response and Breach Notification

Any suspected security breach, unauthorized credential access, or ransomware event must be escalated to the Security Operations Center (SOC) within 4 hours of detection. If customer Personally Identifiable Information (PII) is compromised, external regulatory and customer notifications must be issued within 72 hours.

Section 4.0: SOC 2 Access Auditing and Third-Party Reviews

Annual SOC 2 Type II audits are conducted by an independent certified CPA firm. User access privileges across all production environments are audited and certified on a quarterly basis by department heads.